

Access Control Definitions



Copyright Notice

- This set of transparencies, hereinafter referred to as slides, is protected by copyright laws and provisions of International Treaties. The title and copyright regarding the slides (including, but not limited to, each and every image, photography, animation, video, audio, music and text) are property of the authors specified on page 1.
- The slides may be reproduced and used freely by research institutes, schools and Universities for non-profit, institutional purposes. In such cases, no authorization is requested.
- Any total or partial use or reproduction (including, but not limited to, reproduction on magnetic media, computer networks, and printed reproduction) is forbidden, unless explicitly authorized by the authors by means of written license.
- Information included in these slides is deemed as accurate at the date of publication. Such information is supplied for merely educational purposes and may not be used in designing systems, products, networks, etc. In any case, these slides are subject to changes without any previous notice. The authors do not assume any responsibility for the contents of these slides (including, but not limited to, accuracy, completeness, enforceability, updated-ness of information hereinafter provided).
- In any case, accordance with information hereinafter included must not be declared.
- In any case, this copyright notice must never be removed and must be reported even in partial uses.



Access Control Definitions

- An important requirement of any information management system is to:
 - protect data and resources against unauthorized disclosure (secrecy)
 - unauthorized or improper modifications (integrity),
 - ensuring their availability to legitimate users (no denials-of-service).
- Enforcing protection therefore requires that *every access to a system and its resources be controlled and that all and only authorized accesses can take place.*
- This process goes under the name of **access control** .



Access Control Definitions

- Access control is a major building block of network security, regulating access of legitimate users to resources of a system.
- Access control by itself cannot prevent the occurrence of cyber-attacks.
- However, effective protection schemes cannot abstract from the definition of how access to system resources shall take



Access Control Definitions

NISTIR 7298 defines access control as:

“the process of granting or denying specific requests to:

- (1) obtain and use information and related information processing services;
- (2) enter specific physical facilities”



Access Control Definitions

RFC 4949 defines access control as:

“a process by which use of system resources is regulated according to a security policy and is permitted only by authorized entities (users, programs, processes, or other systems) according to that policy”



Access Control Security Requirements

Access control in theory should allow you to specify:

- Who is authorized To
- what resources For
- how long On
- which days
- With what modality
- By performing which operation



Access Control Security Requirements (SP 800-171)

Table 4.1, from NIST SP 800-171 (*Protecting Controlled Unclassified Information in Nonfederal Information Systems and Organizations* , August 2016), provides a useful list of security requirements for access control services.



Access Control Security Requirements (SP 800-171)

Basic Security Requirements

1. Limit information system access to authorized users, processes acting on behalf of authorized users, or devices (including other information systems).
2. Limit information system access to the types of transactions and functions that authorized users are permitted to execute.



Access Control Security Requirements (SP 800-171)

Derived Security Requirements

3. Control the flow of Controlled Unclassified Information in accordance with approved authorizations.
4. Separate the duties of individuals to reduce the risk of malevolent activity without collusion.
5. Employ the principle of least privilege, including for specific security functions and privileged accounts.



Access Control Security Requirements (SP 800-171)

Derived Security Requirements

5. Prevent non-privileged users from executing privileged functions and audit the execution of such functions.
6. Limit unsuccessful logon attempts.
7. Provide privacy and security notices consistent with applicable Controlled Unclassified Information rules.



Access Control Security Requirements (SP 800-171)

Derived Security Requirements

- 10. Use session lock with pattern-hiding displays to prevent access and viewing of data after period of inactivity.
- 11. Terminate (automatically) a user session after a defined condition.
- 12. Monitor and control remote access sessions.
- 13. Employ cryptographic mechanisms to protect the confidentiality of remote access sessions.



Access Control Security Requirements (SP 800-171)

Derived Security Requirements

- 14. Route remote access via managed access control points.
- 15. Authorize remote execution of privileged commands and remote access to security-relevant information.
- 16. Authorize wireless access prior to allowing such connections.
- 17. Protect wireless access using authentication and encryption.
- 18. Control connection of mobile devices.



Access Control Security Requirements (SP 800-171)

Derived Security Requirements

- 19. Encrypt *Controlled Unclassified Information* on mobile devices.
- 20. Verify and control/limit connections to and use of external information systems.
- 21. Limit use of organizational portable storage devices on external information systems.
- 22. Control *Controlled Unclassified Information* posted or processed on publicly accessible information systems.



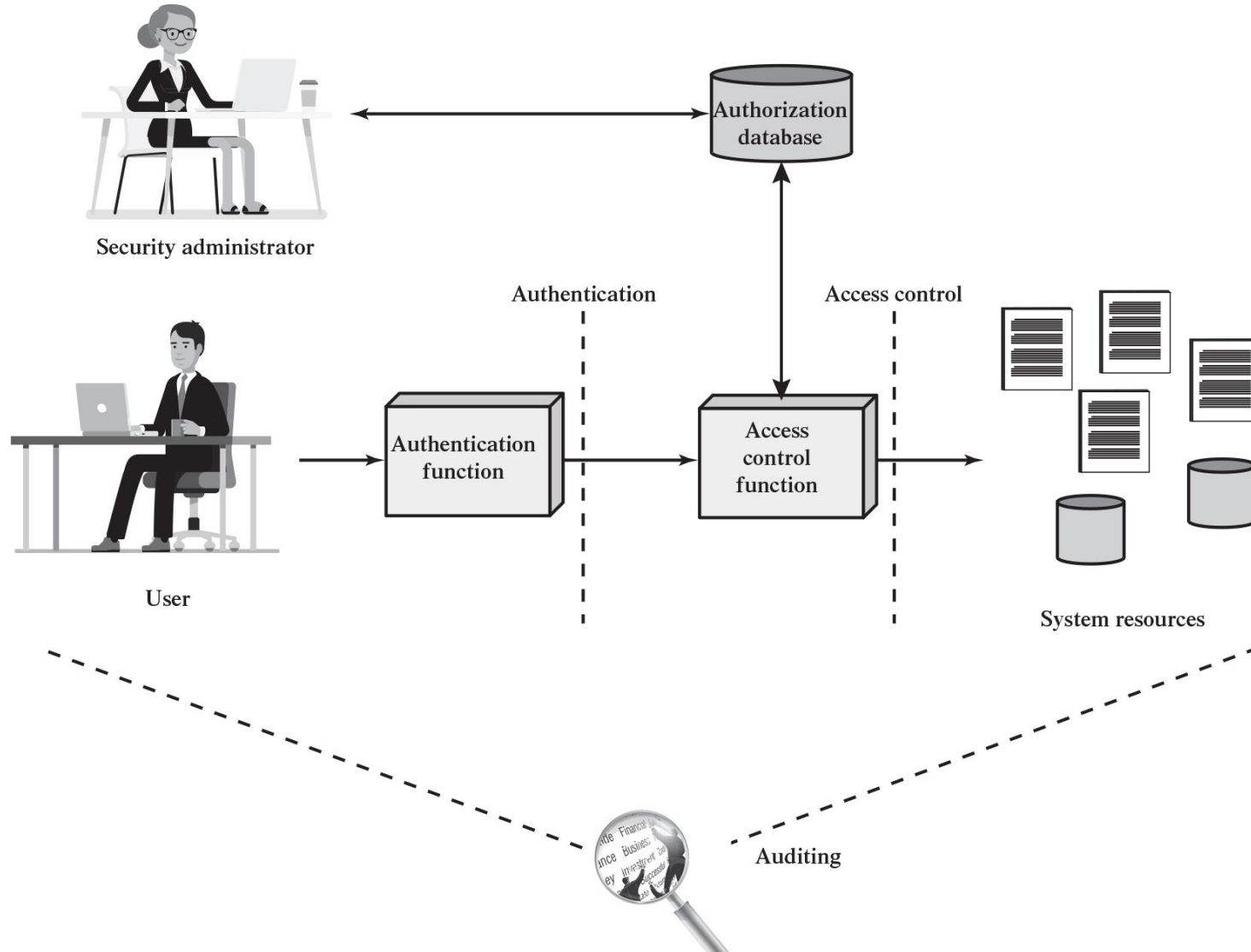
Access Control Principles

- In a broad sense, all of computer security is concerned with access control
- **RFC 4949** defines computer security as:

“measures that implement and assure security services in a computer system, particularly those that assure access control service”

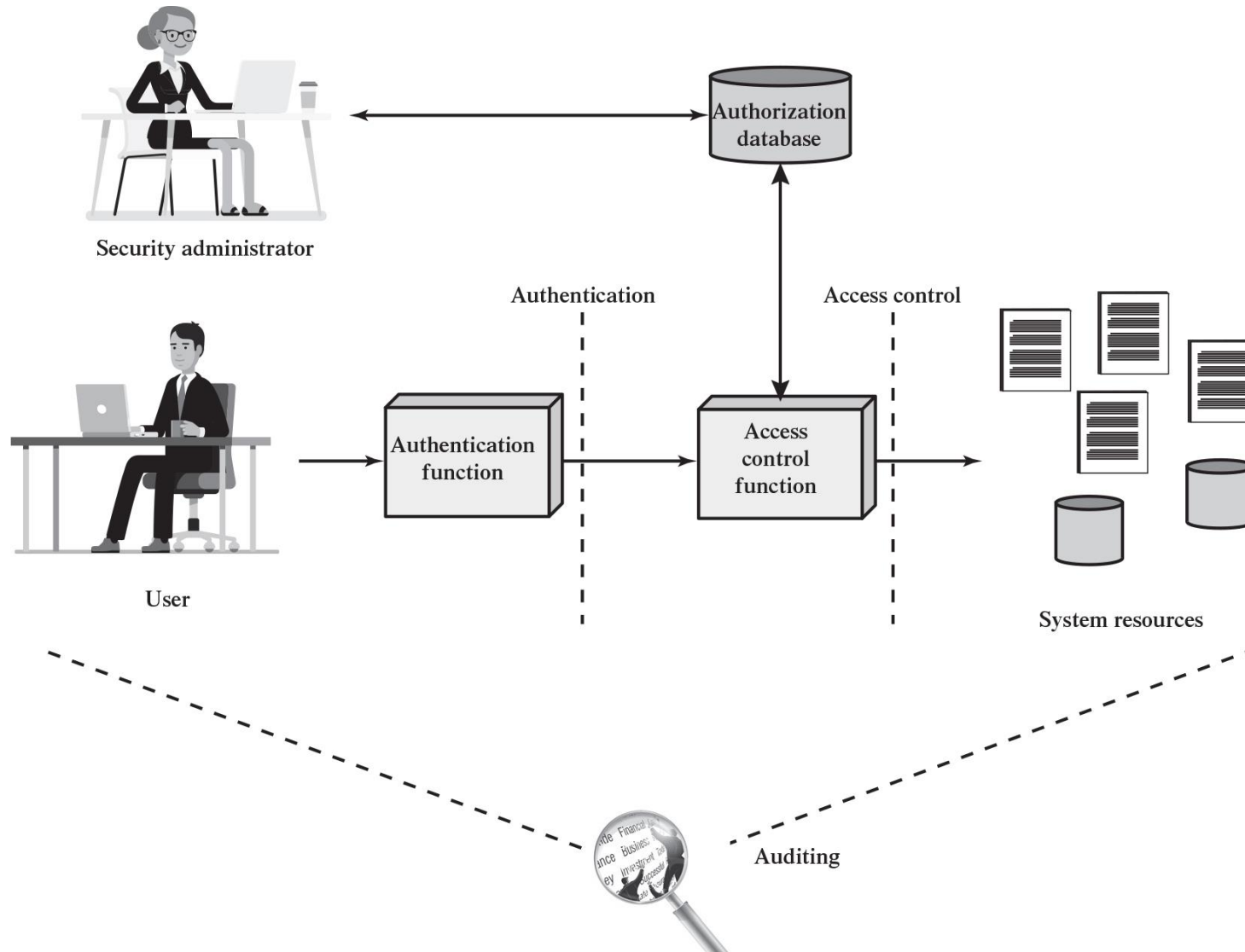


Relationship Among Access Control and Other Security Functions



1) Authentication:
Verification that the credentials of a user or other system entity are valid.

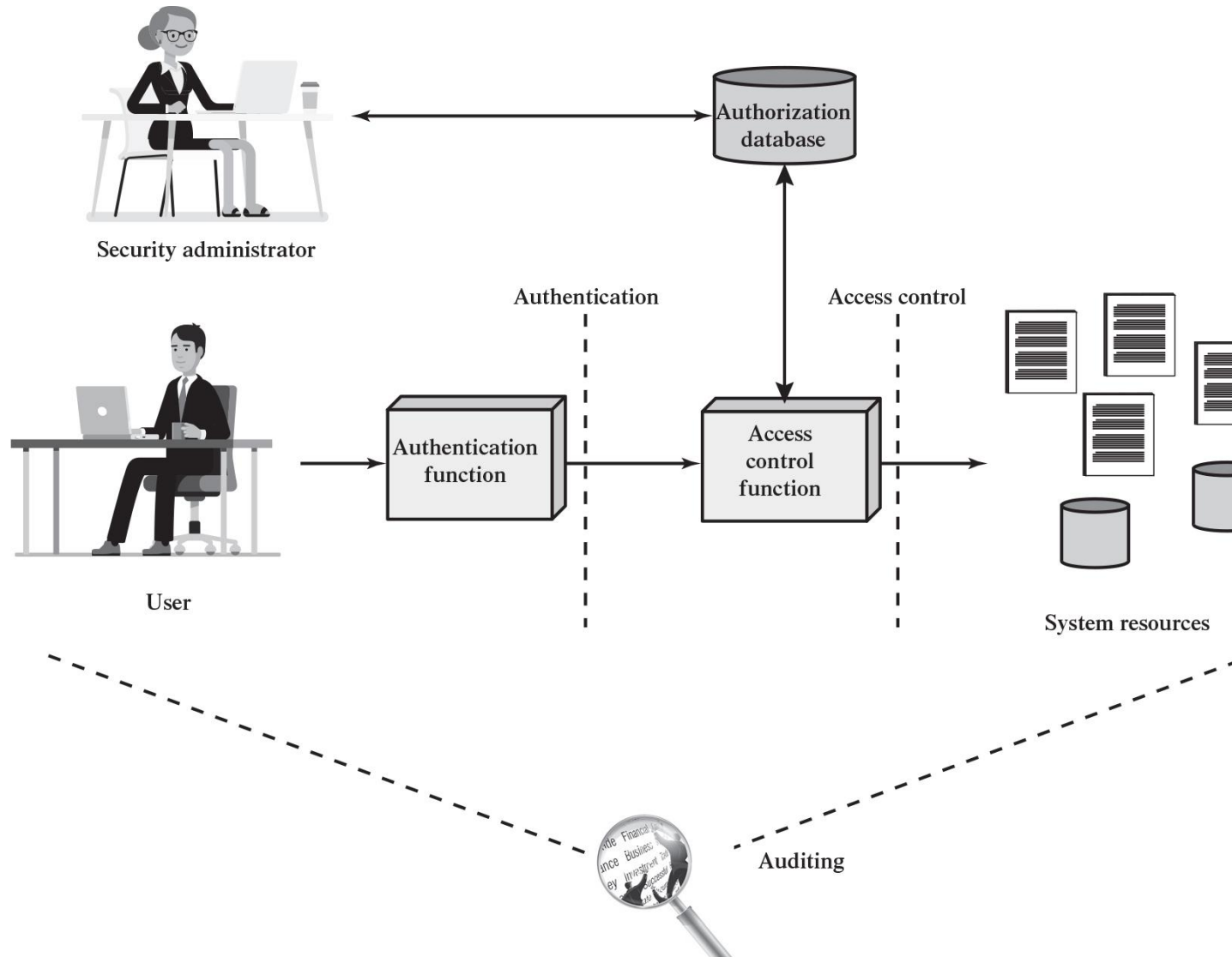
Relationship Among Access Control and Other Security Functions



2) Authorization:

The granting of a right or permission to a system entity to access a system resource. This function determines who is trusted for a given purpose.

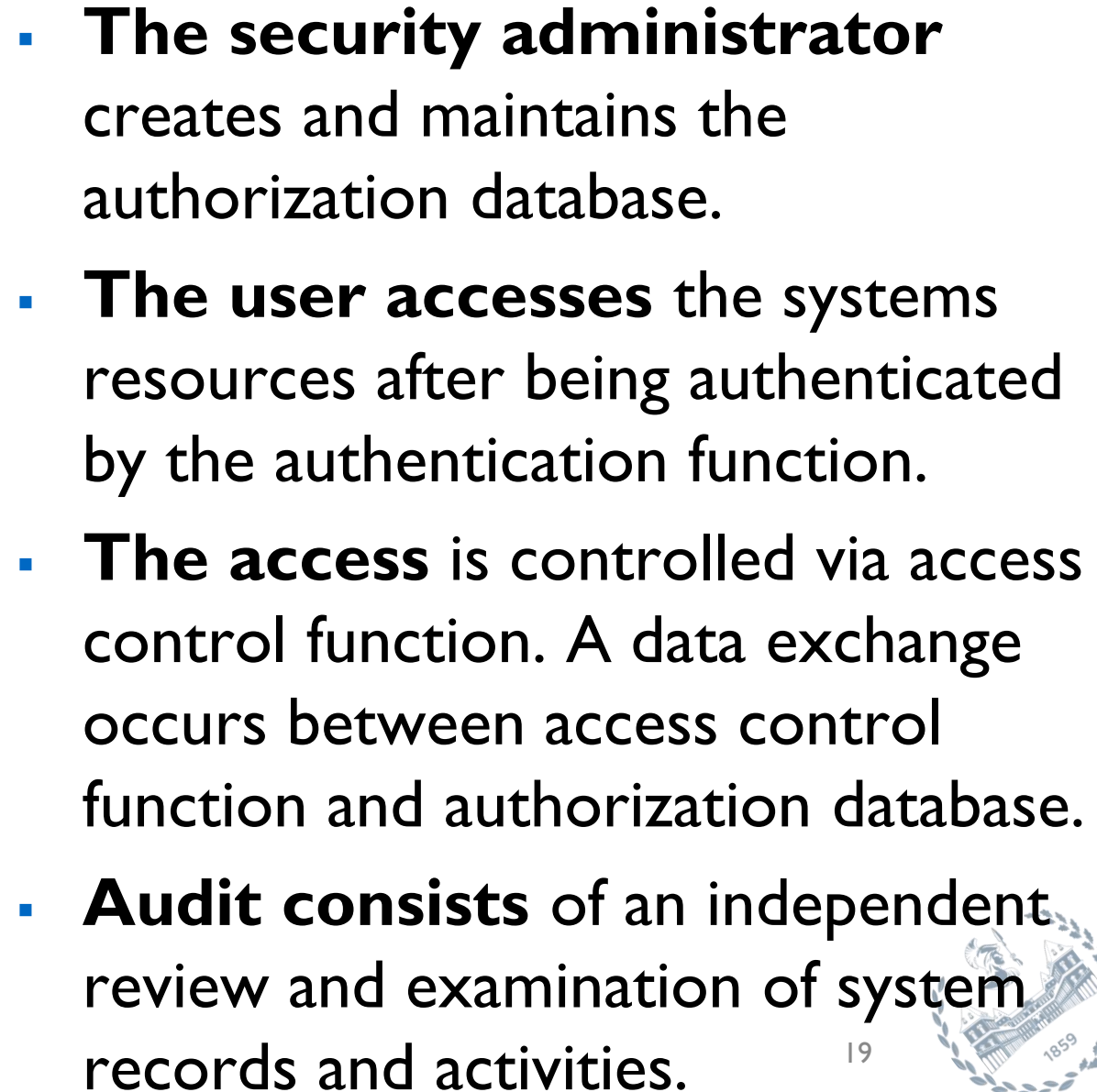
Relationship Among Access Control and Other Security Functions



3 Audit:

An independent review and examination of system records and activities in order to verify for adequacy of system controls, to ensure compliance with established policy and operational procedures, to detect breaches in security, and to recommend any indicated changes in control, policy and procedures.

Security administrator



Authentication

**Authentication techniques,
protocols, and architectures**

Antonio Lioy
< lioy @ polito.it >

Politecnico di Torino
Dip. Automatica e Informatica



Internal and External Audit

- The auditing processes of information technology (IT) enterprises are divided into two types as:
 - **internal audit**
 - **external audit.**



Internal Audit

- Internal auditing is performed by auditors (employees) internally in the organization.
- The purposes of the internal auditors are to identify the risks whenever they arise related to the performance, security and compliance issues.
- They also keep a watch on what are being done to mitigate those problems aiming to help the organization perform better.



External Audit

- External audit is carried out by professional auditors external to the organization.
- They are independent body, often being certified public accountants (CPAs), and perform an independent auditing of the organization.
- The shareholders and clients of any organization pay more attention and importance to this external audit report regarding performance, security and compliance of the system.

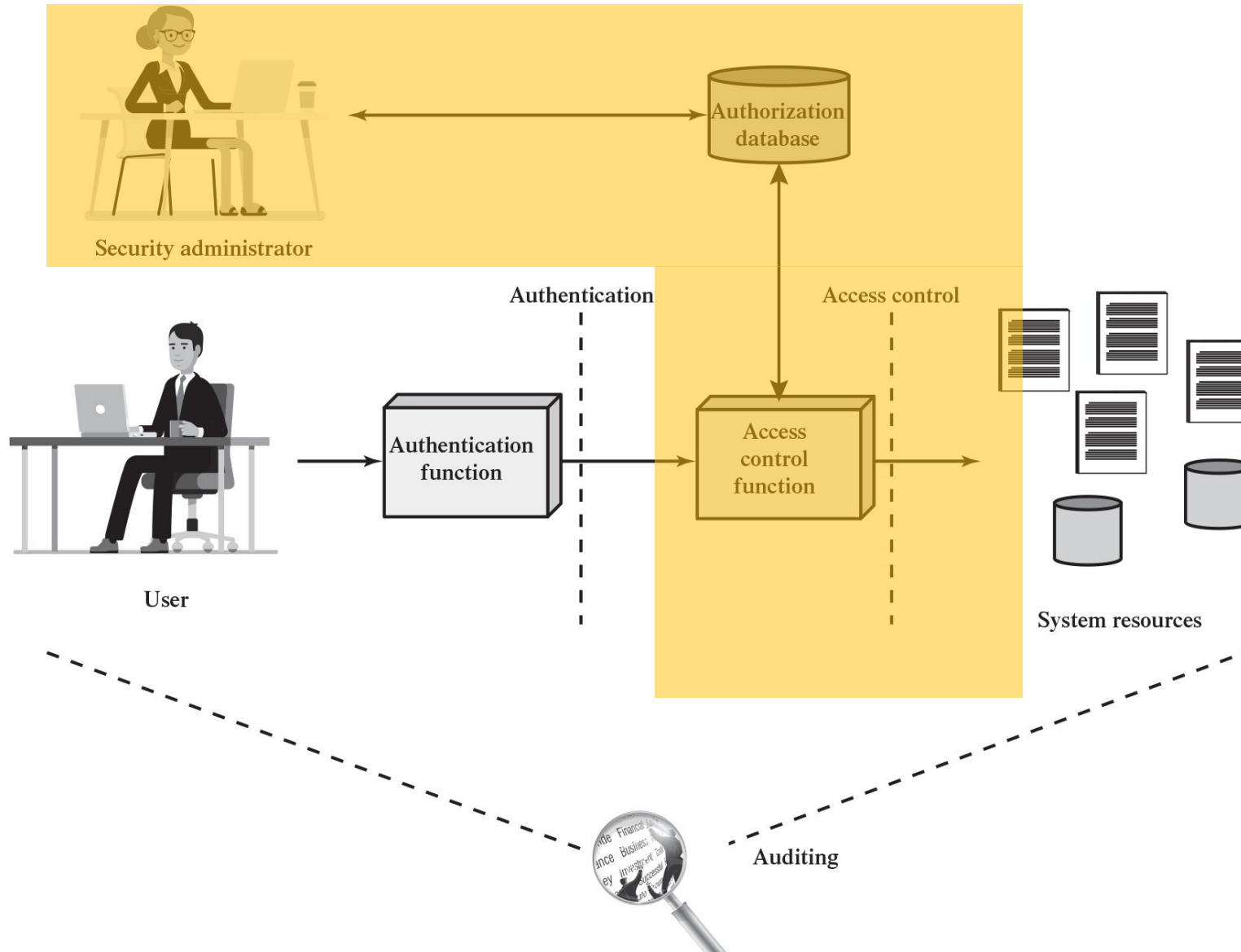


Differences between internal and external audit

<i>Internal Audit</i>	<i>External Audit</i>
It is performed by auditors who are employees of the organization.	It is performed by the external professional auditing body.
Auditors generally have much wider authorizations.	Auditors generally have restricted authorizations.
The objective is to identify loopholes in processes for betterment of the organization.	External auditing is done by the organization to build confidence among clients and shareholders.
Audit report is not published outside, it is used only for internal purpose.	Audit report is published outside of the organization.
It can be executed anytime. Generally, it is done on regular basis.	It does not happen too frequently. Generally it occurs once in a year.

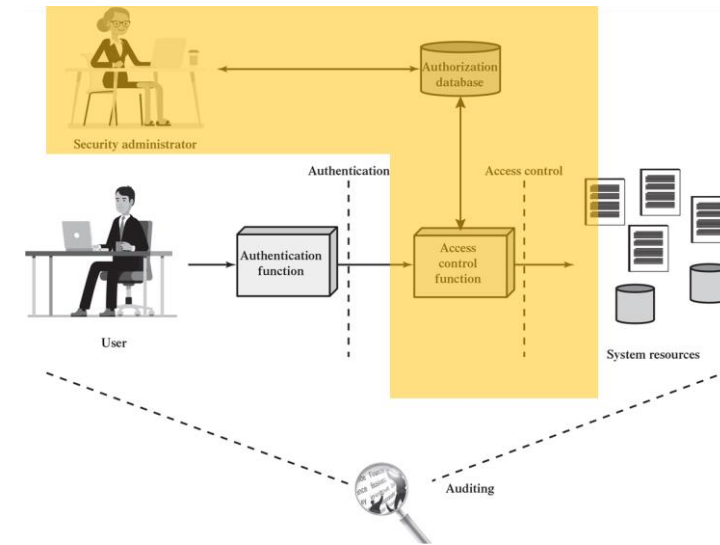


An access control mechanism



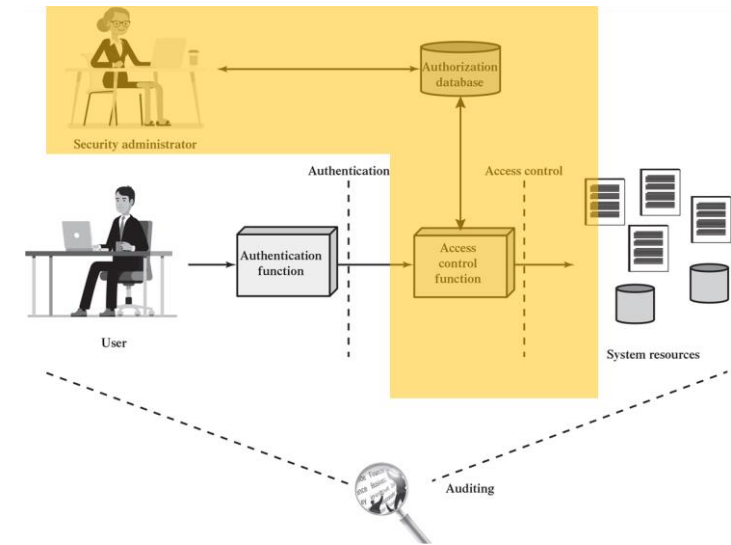
An access control mechanism

- An access control mechanism **mediates** between a user (or a process executing on behalf of a user) and system resources, such as applications, operating systems, firewalls, routers, files, and databases.
- The system must first authenticate an entity seeking access. Typically, the authentication function determines whether the user is permitted to access the system at all.



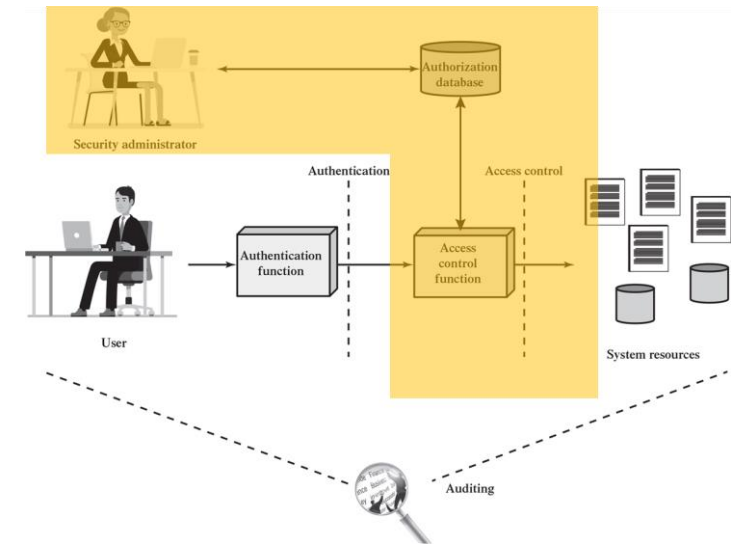
An access control mechanism

- Then the access control function determines if the specific requested access by this user is permitted.
- A security administrator maintains an authorization database that specifies what type of access to which resources is allowed for this user.
- The access control function consults this database to determine whether to grant access



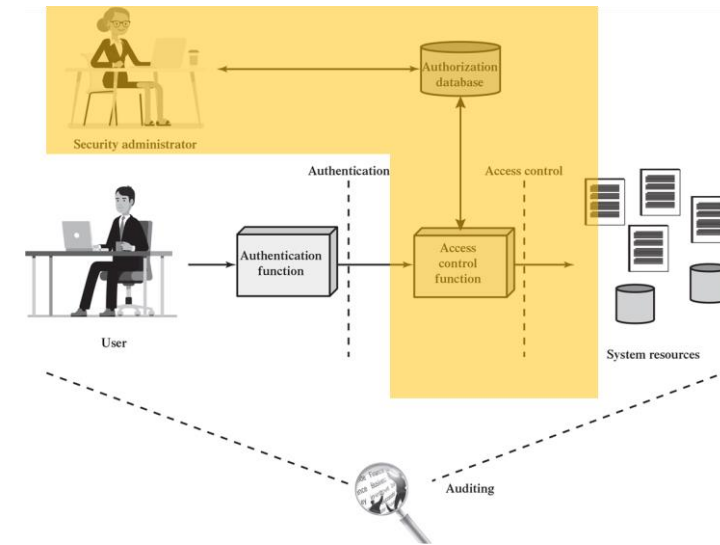
An access control mechanism

- In the simple model show in Figure, the access control function is shown as a single logical module.
- In practice, a number of components may cooperatively share the access control function.



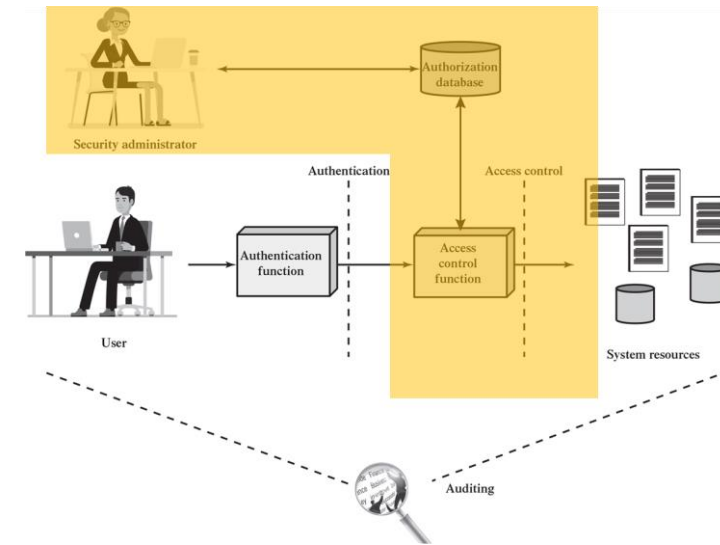
An access control mechanism

- All **operating systems** have at least a rudimentary, and in many cases a quite robust, access control component.
- **Add-on security packages** can supplement the native access control capabilities of the OS.
- **Particular applications** or utilities, such as a database management system, also incorporate access control functions.



An access control mechanism

- External devices, **such as firewalls**, can also provide access control services.



An access control mechanism

In brief, the process is usually carried out with a multi-phase approach based on the following concepts:

- **Security mechanism**
- **Security policy**
- **Security model**



Security mechanism

- It defines the low level (software and hardware) functions that implement the controls imposed by the policy and formally stated in the model
- In particular, the separation between policies and mechanisms introduces an independence between protection requirements to be enforced on the one side, and mechanisms enforcing them on the other.



Separation between policies and mechanisms

It is then possible to:

- i) discuss protection requirements independently of their implementation,
 - ii) compare different access control policies as well as different mechanisms that enforce the same policy
 - iii) design mechanisms able to enforce multiple policies
-
- This latter aspect is particularly important: if a mechanism is tied to a specific policy, a change in the policy would require changing the whole access control system



Access Control Policies

- It defines the (high-level) rules according to which access control must be regulated
- An access control policy, which can be embodied in an authorization database,
- A policy dictates what types of access are permitted, under what circumstances, and by whom.



Access Control Policy Model

- It provides a formal representation of the access control security policy and its working.
- The formalization allows the proof of properties on the security provided by the access control system being designed.



Access Control Policies

- Access control policies regulate the access of users to the resources of a networked system by defining **“who is allowed to do what on what”**.



Subjects, Objects, and Access Rights

A first step in the development of an access control system based on DAC is:

- the identification of the **objects** to be protected,
- the **subjects** that execute activities and request access to objects,
- the **actions** that can be executed on the objects, and that must be controlled



Subjects, Objects, and Action

- Subjects, objects, and actions may be different in different systems or application contexts
- For instance, in the protection of operating systems, objects are typically files, directories, or programs; in database systems, objects can be relations, views, stored procedures, and so on.



Subjects

- A subject is an entity capable of accessing objects.
- Generally, the concept of subject equates with that of process. Any user or application actually gains access to an object by means of a process that represents that user or application.
- *A subject is typically held accountable for the actions they have initiated, and an audit trail may be used to record the association of a subject with security relevant actions performed on an object by the subject.*



Subjects

- Subject can create additional subjects (e.g., children processes) in order to accomplish its task.
- The creator subject acquires control privileges on the created processes (e.g., to be able to suspend or terminate its children).



Object

- An object is a resource to which access is controlled.
- In general, an object is an entity used to contain and/or receive information.
 - Examples include records, blocks, pages, segments, files, portions of files, directories, directory trees, mailboxes, messages, and programs.
 - Some access control systems also encompass, bits, bytes, words, processors, communication ports, clocks, and network nodes.



Object

- The number and types of objects to be protected by an access control system depends on the environment in which access control operates and the desired tradeoff between security on the one hand and complexity, processing burden, and ease of use on the other hand.



Action (or Operation)

- It represents what a subject can do in terms of Action or Operation into an object
- In most cases, an action is an **access right** that describes how a subject may access an object. Access rights typically would include: *Read, Write, Execute*



Access Rights

- **Read:** User may view information in a system resource (e.g., a file, selected records in a file, selected fields within a record, or some combination). Read access includes the ability to copy or print.
- **Write:** User may add, modify, or delete data in system resource (e.g., files, records, programs). Write access includes read access.
- **Execute:** User may execute specified programs.



Access Rights

- **Delete:** User may delete certain system resources, such as files or records.
- **Create:** User may create new files, records, or fields.
- **Search:** User may list the files in a directory or otherwise search the directory.



Access Control Policies Model

Access control policy model are generally grouped into:

- **Discretionary access control (DAC)**
 - Controls access based on the identity of the requestor and on access rules (authorizations) stating what requestors are (or are not) allowed to do
- **Mandatory access control (MAC)**
 - Controls access based on comparing security labels with security clearances
- **Role-based access control (RBAC)**
 - Controls access based on the roles that users have within the system and on rules stating what accesses are allowed to users in given roles
- **Attribute-based access control (ABAC)**
 - Controls access based on attributes of the user, the resource to be accessed, and current environmental conditions



Access Control Policies Model

- These four policies are not mutually exclusive. An access control mechanism may employ two or even all three of these policies to cover different classes of system resources.
- Policies (especially Discretionary and role-based) are usually coupled with (or include) an **administrative policy** that defines who can specify authorizations/rules governing access control.



Discretionary Access Control (DAC)

- Discretionary policies enforce access control on the basis of the identity of the requestors and explicit access rules that establish who can, or cannot, execute which actions on which resources.
- They are called discretionary as users can be given the ability of passing on their privileges to other users, where granting and revocation of privileges is regulated by an administrative policy.



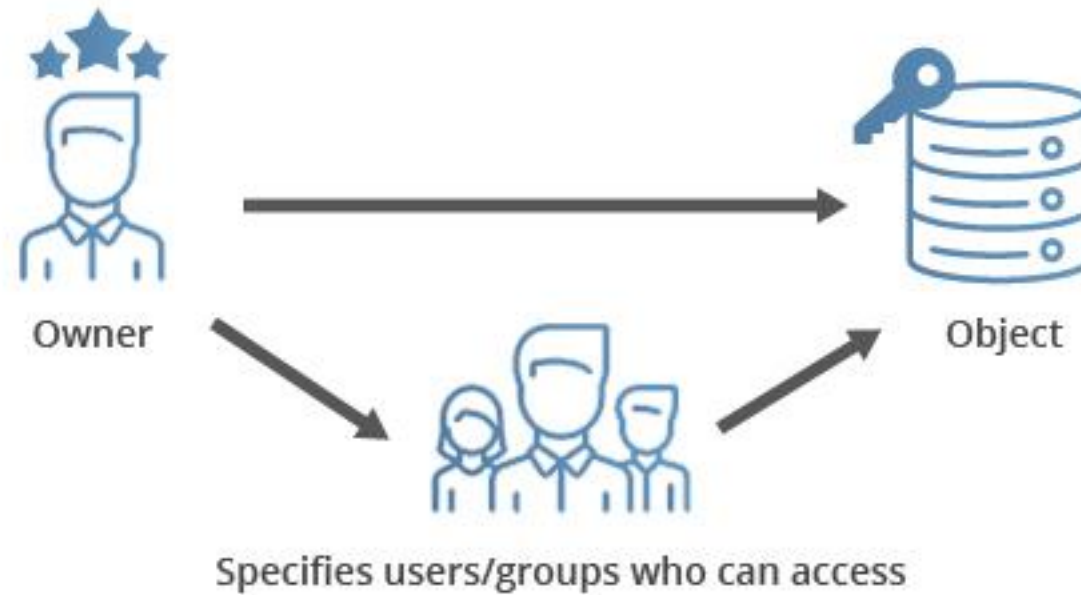
Discretionary Access Control (DAC)

- Often provided using an access matrix
 - One dimension consists of identified subjects that may attempt data access to the resources
 - The other dimension lists the objects that may be accessed
- Each entry in the matrix indicates the access rights of a particular subject for a particular object
- This model is called access matrix since the authorization state, meaning the authorizations holding at a given time in the system, is represented as a matrix
- The matrix therefore gives an abstract representation of protection systems.

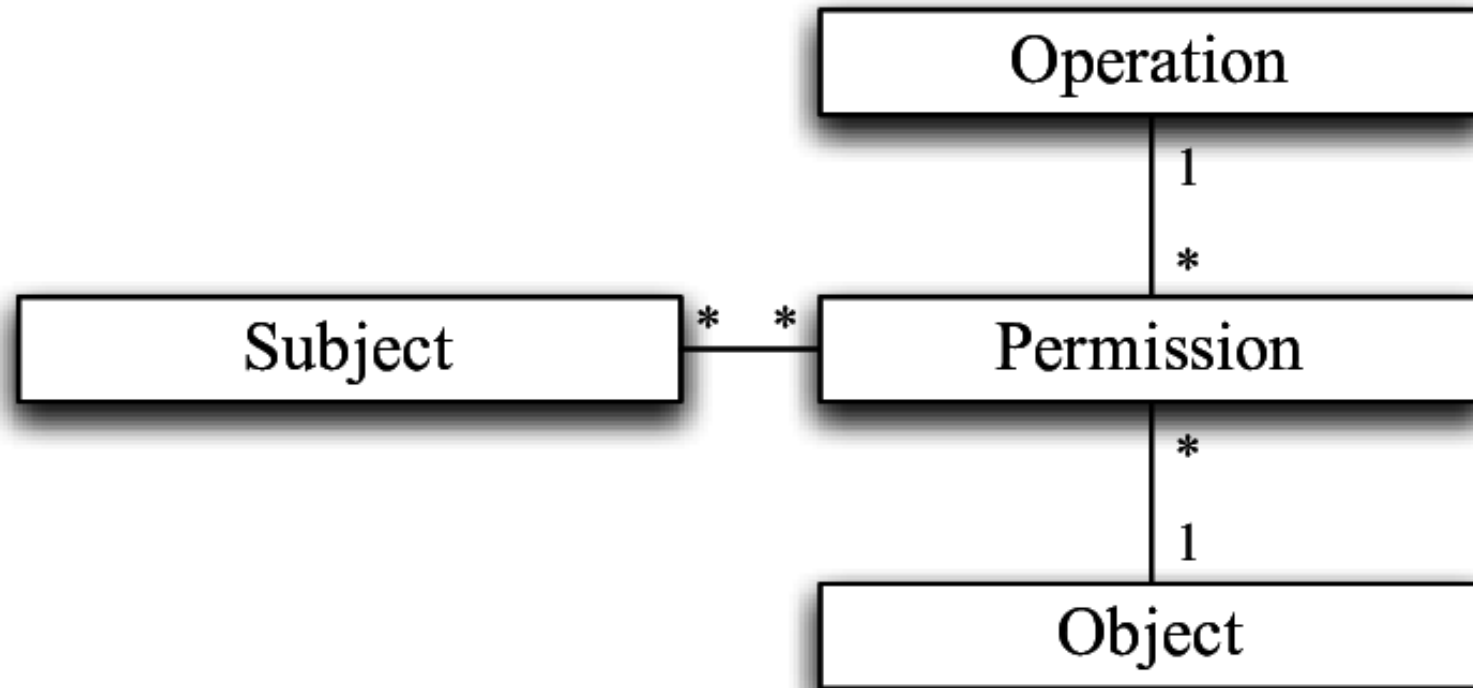


Discretionary Access Control (DAC)

Discretionary Access Control (DAC)



Discretionary Access Control (DAC)



Example of Access Control Structures

		OBJECTS			
		File 1	File 2	File 3	File 4
SUBJECTS	User A	Own Read Write		Own Read Write	
	User B	Read	Own Read Write	Write	Read
	User C	Read Write	Read		Own Read Write

(a) Access matrix



Implementation of the Access Matrix

- Although the matrix represents a good conceptualization of authorizations, it is not appropriate for implementation.
- In a general system, the access matrix will be usually enormous in size and sparse (most of its cells are likely to be empty).
- Storing the matrix as a two-dimensional array is therefore a waste of memory space.



Implementation of the Access Matrix

There are three approaches to implementing the access matrix in a practical way:

- **Authorization Table**
- **Access Control List (ACL)**
- **Capability**



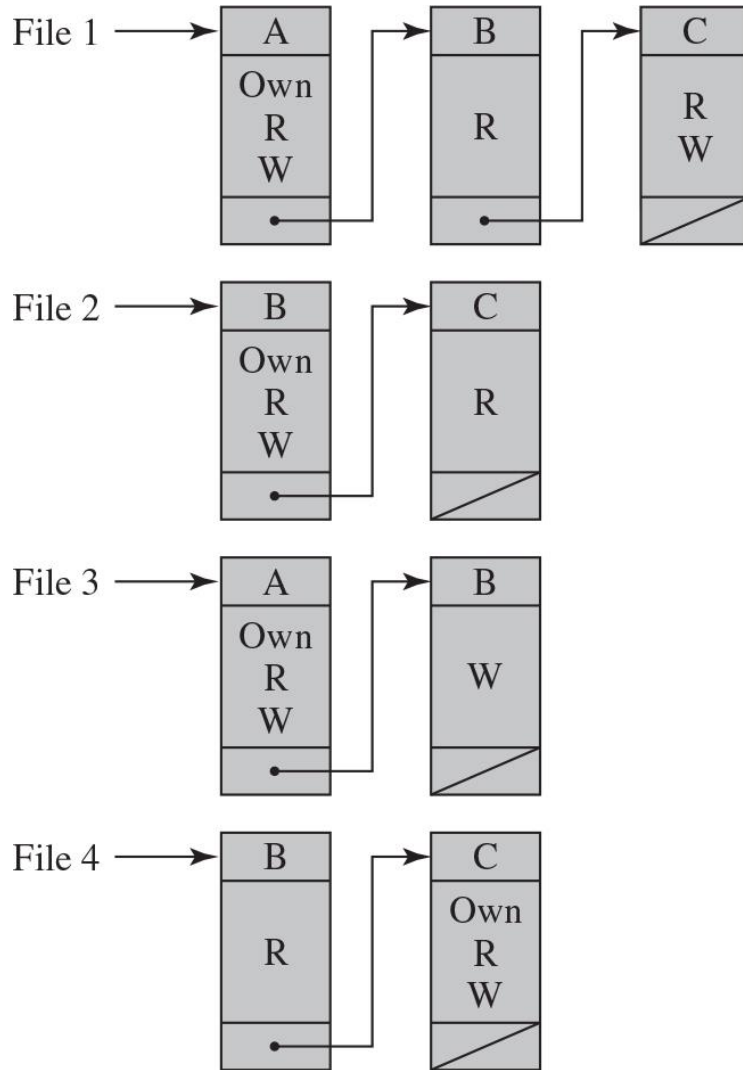
Authorization Table

Subject	Access Mode	Object
A	Own	File 1
A	Read	File 1
A	Write	File 1
A	Own	File 3
A	Read	File 3
A	Write	File 3
B	Read	File 1
B	Own	File 2
B	Read	File 2
B	Write	File 2
B	Write	File 3
B	Read	File 4

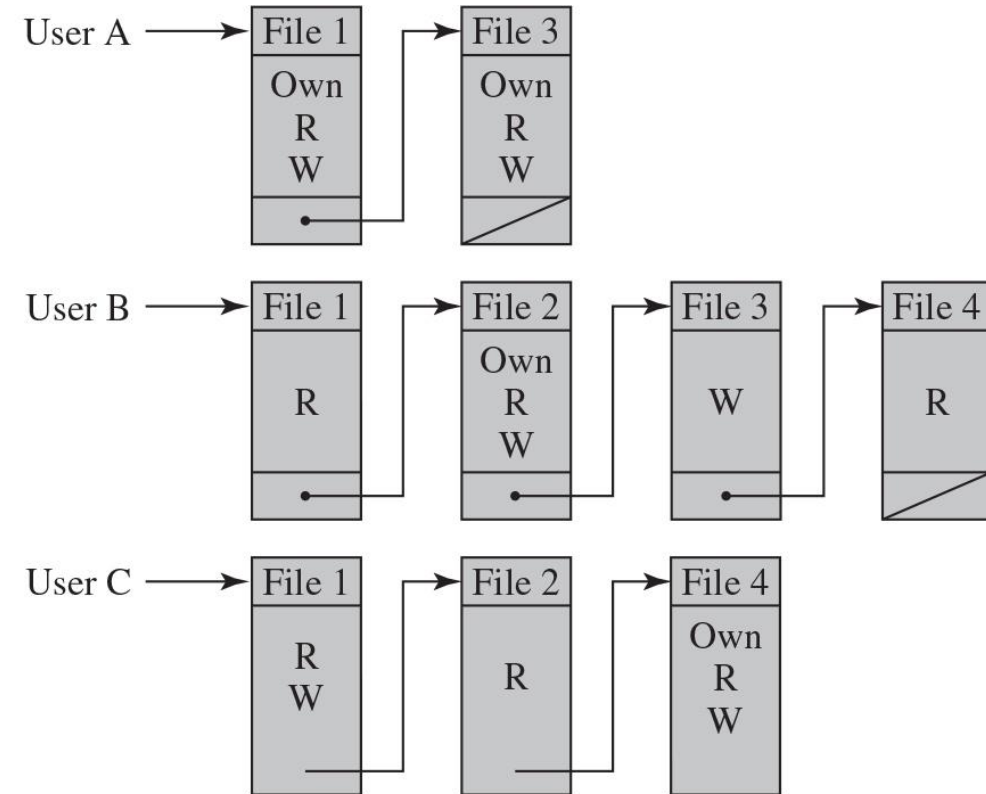
Subject	Access Mode	Object
C	Read	File 1
C	Write	File 1
C	Read	File 2
C	Own	File 4
C	Read	File 4
C	Write	File 4



Access Control List (ACL) e Capability



(b) Access control lists for files of part (a)



(c) Capability lists for files of part (a)

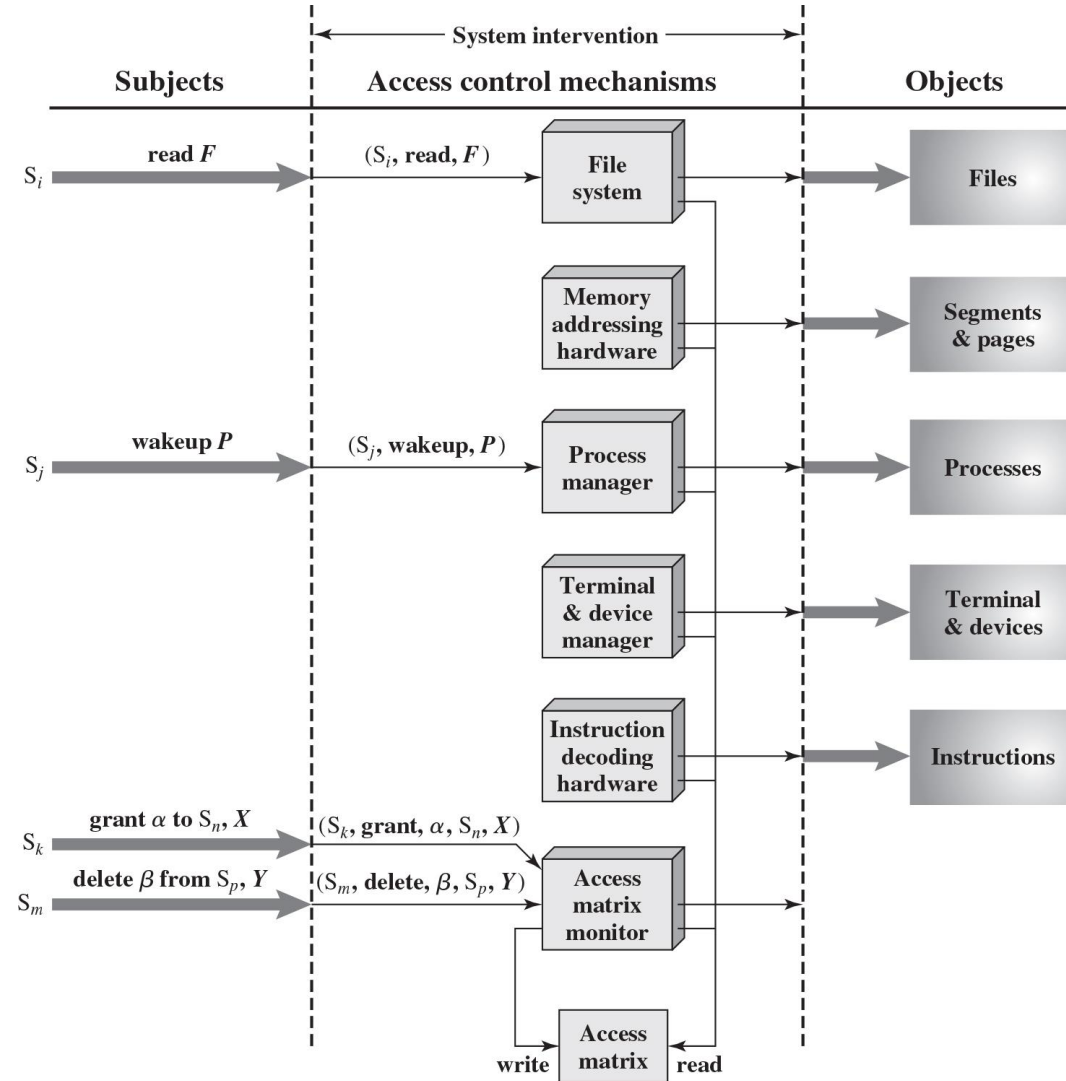
Example of an Extended Access Control Matrix

		OBJECTS								
		Subjects			Files		Processes		Disk drives	
		S_1	S_2	S_3	F_1	F_2	P_1	P_2	D_1	D_2
SUBJECTS	S_1	control	owner	owner control	read*	read owner	wakeup	wakeup	seek	owner
	S_2		control		write*	execute			owner	seek*
	S_3			control		write	stop			

* = copy flag set



An Organization of the Access Control Function



Mandatory access control (MAC)

- It controls access by comparing security labels (which indicate how sensitive or critical system resources are) with security permissions (which indicate that system entities are eligible to access certain resources).
- This policy is called mandatory because an entity that has permission to access a resource cannot, by its own volition, allow another entity to access that resource.



Mandatory access control (MAC)

Mandatory Access Control (MAC)



Role-Based Access Control Models

- Role-based access control (RBAC) is an alternative to traditional discretionary (DAC) and mandatory access control (MAC) policies that is attracting increasing attention, particularly for commercial applications.
- The main motivation behind RBAC is the necessity to specify and enforce enterprise-specific security policies in a way that maps naturally to an organization's structure. In fact, in a large number of business activities a user's identity is relevant only from the point of view of accountability.



Role-Based Access Control Models

- For access control purposes it is much more important to know what a user's organizational responsibilities are, rather than who the user is.
- The conventional discretionary access controls, in which individual user ownership of data plays such an important part, are not a good fit.
- Neither are the full mandatory access controls, in which users have security clearances and objects have security classifications.
- Role-based access control tries to fill in this gap by merging the flexibility of explicit authorizations with additionally imposed organizational constraints.

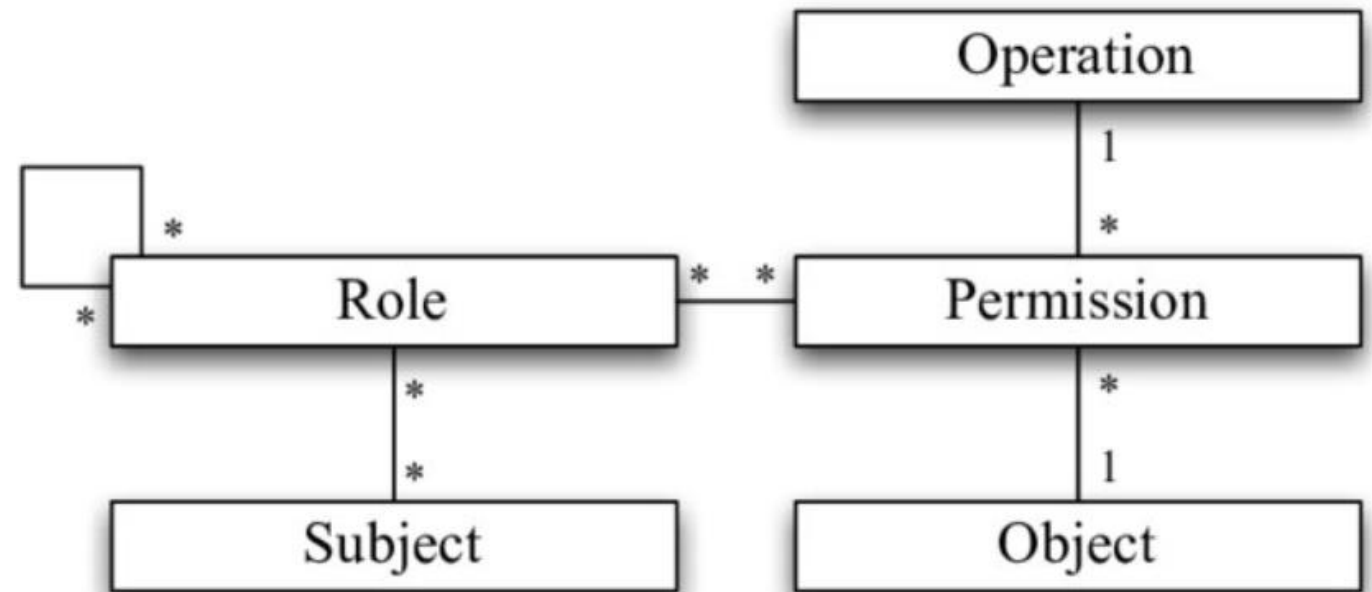
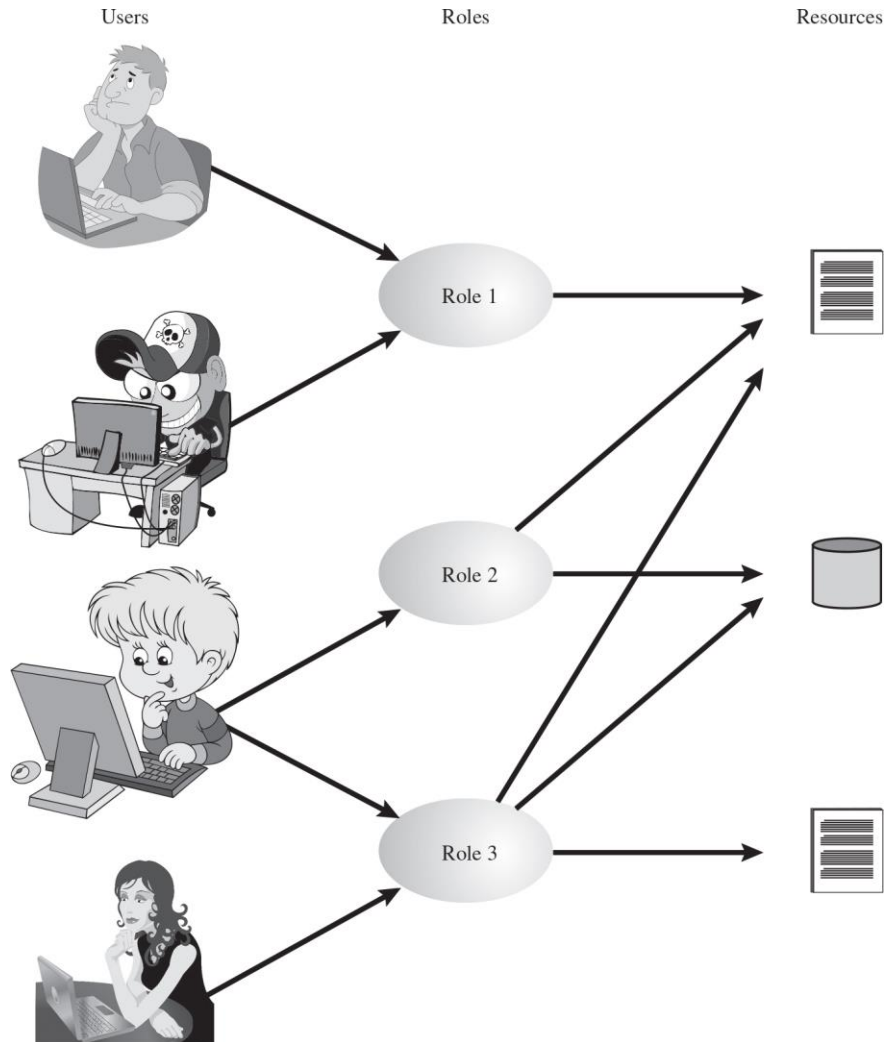


Role-Based Access Control Models

- Traditional DAC systems define the access rights of individual users and groups of users.
- In contrast, RBAC is based on the roles that users assume in a system rather than the user's identity.
- Typically, RBAC models define a role as a job function within an organization.
- RBAC systems assign access rights to roles instead of individual users. In turn, users are assigned to different roles, either statically or dynamically, according to their responsibilities.



Users, Roles, and Resources



Role-Based Access Control Models

- The relationship of users to roles is many to many, as is the relationship of roles to resources, or system objects
- The set of users changes, in some environments frequently, and the assignment of a user to one or more roles may also be dynamic.
- The set of roles in the system in most environments is relatively static, with only occasional additions or deletions.
- Each role will have specific access rights to one or more resources. The set of resources and the specific access rights associated with a particular role are also likely to change infrequently.



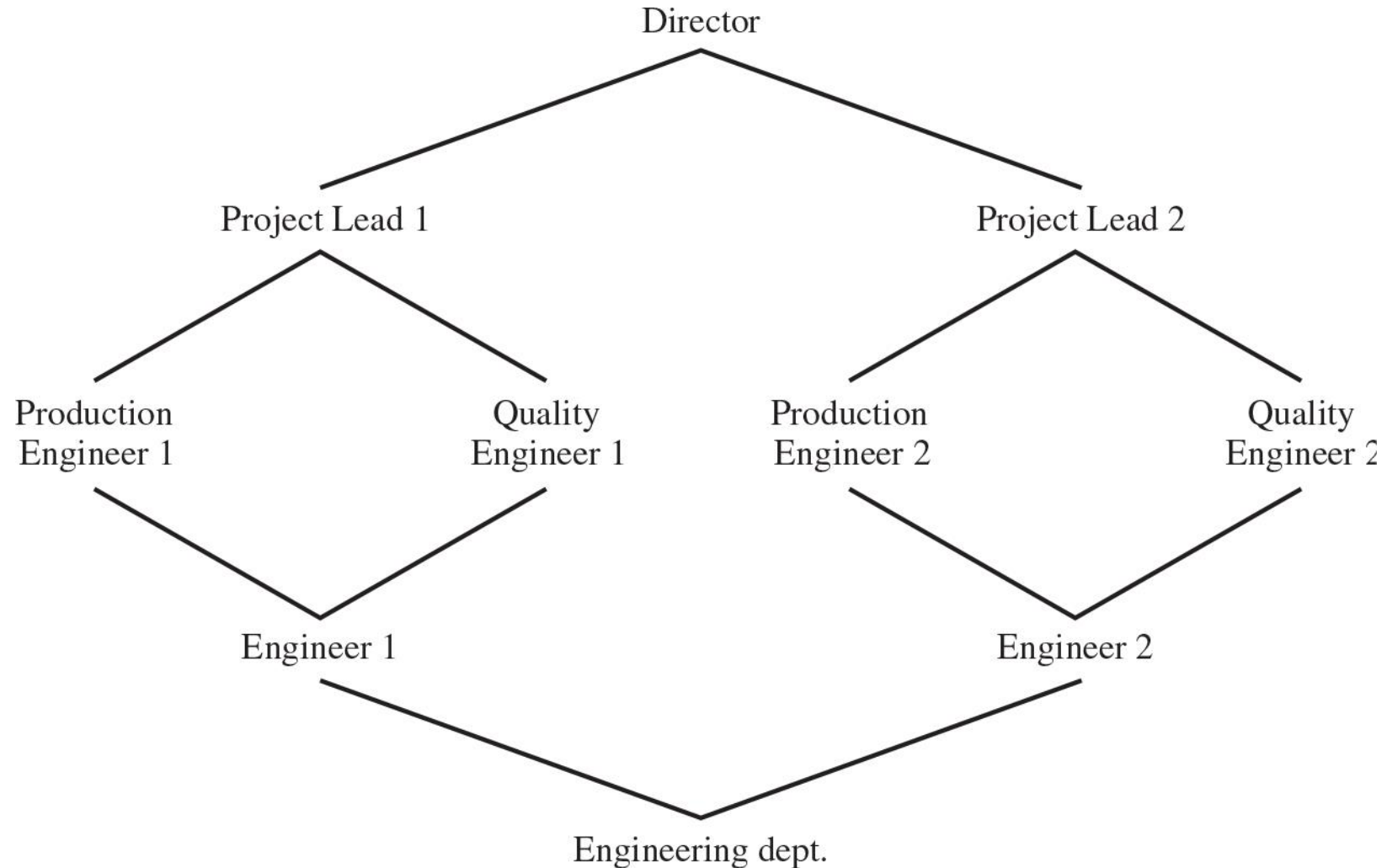
Access Control Matrix Representation of RBAC

	R ₁	R ₂	• • •	R _n
U ₁	✕			
U ₂	✕			
U ₃		✕		✕
U ₄				✕
U ₅				✕
U ₆				✕
•				
•				
•				
U _m	✕			

		OBJECTS								
		R ₁	R ₂	R _n	F ₁	F ₂	P ₁	P ₂	D ₁	D ₂
ROLES	R ₁	control	owner	owner control	read *	read owner	wakeup	wakeup	seek	owner
	R ₂		control		write *	execute			owner	seek *
	•									
	•									
	R _n			control		write	stop			



Example of Role Hierarchy



Role Hierarchy

- Role hierarchies provide a means of reflecting the hierarchical structure of roles in an organization.
- Typically, job functions with greater responsibility have greater authority to access resources.
- A subordinate job function **may have a subset of the access rights of the superior job function.**
- Role hierarchies make use of the concept of **inheritance** to enable one role to implicitly include access rights associated with a subordinate role.



Least Privilege

- The principle of least privilege maintains that an individual, process, or other type of entity should be given the minimum privileges and resources for the minimum period of time required to complete a task.
- This approach reduces the opportunity for unauthorized access to sensitive information.



Separation of privilege

- The principle of *separation of privilege* suggests to break a single privilege among multiple independent subjects (component or user) so that more than one authorizations are required to perform an action.
- This protects the system from someone's evil intention.



Constraints - RBAC

Provide a means of adapting RBAC to the specifics of administrative and security policies of an organization. A defined relationship among roles or a condition related to roles

- **Mutually exclusive roles**

- A user can only be assigned to one role in the set (either during a session or statically)
- Any permission (access right) can be granted to only one role in the set

- **Cardinality**

- Setting a maximum number with respect to roles

- **Prerequisite roles**

- Dictates that a user can only be assigned to a particular role if it is already assigned to some other specified role

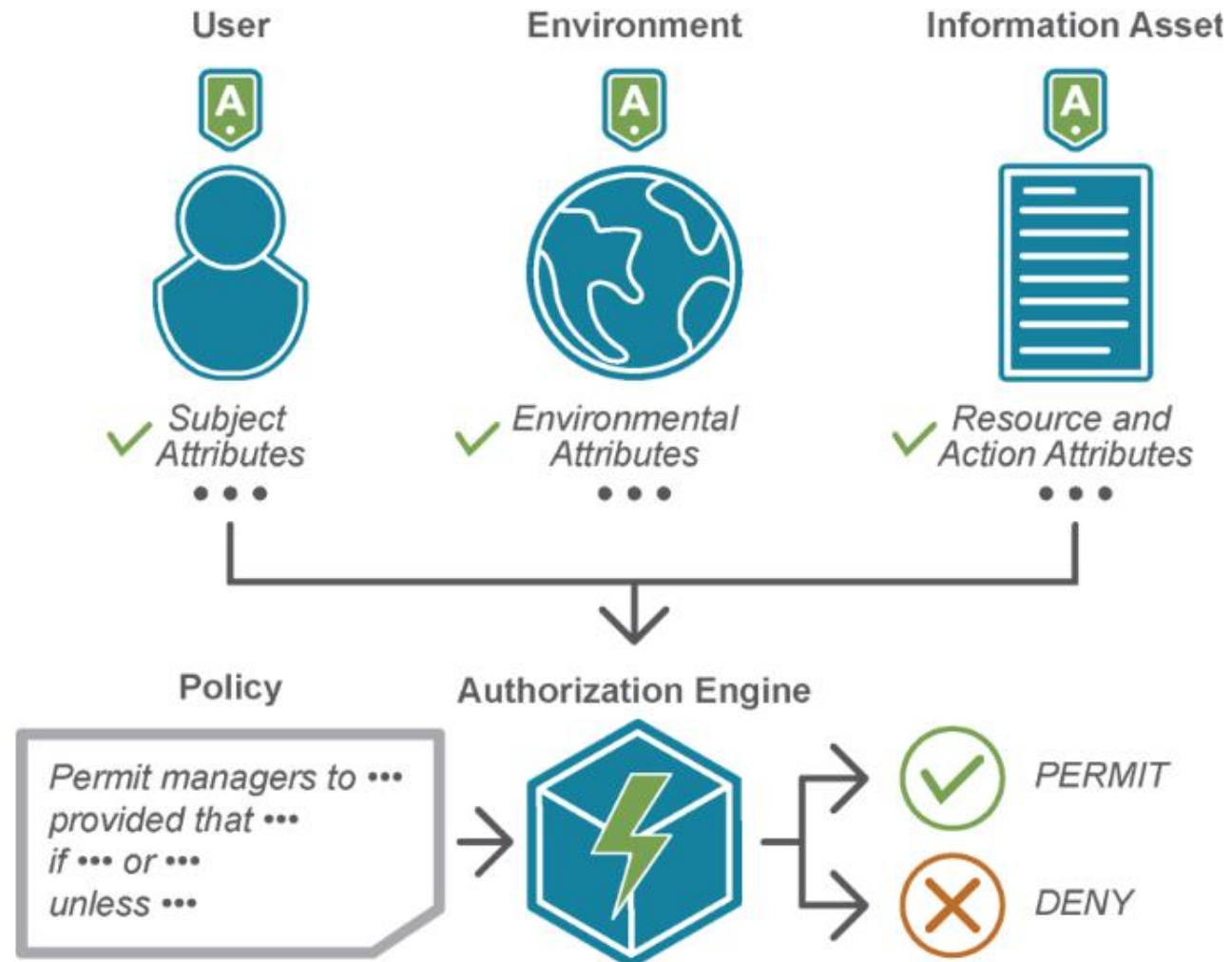


Attribute-Based Access Control (ABAC)

- A relatively recent development in access control technology is the attribute-based access control (ABAC) model.
- An ABAC model can define authorizations that express conditions on properties of both the resource and the subject
- The strength of the ABAC approach is its flexibility and expressive power



ABAC Model



ABAC Model

- It is clear from the logical architecture that there are four independent sources of information used for the access control decision.
- The system designer can decide which attributes are important for access control with respect to subjects, objects, and environmental conditions.
- The system designer or other authority can then define access control policies, in the form of rules, for any desired combination of attributes of subject, object, and environmental conditions.



ABAC Model

- It should be evident that this approach is very powerful and flexible.
- However, the cost, both in terms of the complexity of the design and implementation and in terms of the performance impact, is likely to exceed that of other access control approaches.
- This is a tradeoff that the system authority must make.
- **ABAC are capable of enforcing DAC, RBAC, and MAC concepts**



ABAC Model: Attributes

- Attributes are characteristics that define specific aspects of the subject, object, environment conditions, and/or requested operations that are predefined and preassigned by an authority.

Three types of attributes in the ABAC model:

- **Subject attributes**
- **Object attributes**
- **Environment attributes**



ABAC Model: Subject attributes

- A subject is an active entity (e.g., a user, an application, a process, or a device) that causes information to flow among objects or changes the system state.
- Each subject has associated attributes that define the identity and characteristics of the subject.
- Such attributes may include the subject's identifier, name, organization, job title, and so on.
- **A subject's role can also be viewed as an attribute.**



ABAC Model: Object attributes

- An object, also referred to as a resource , is a passive (in the context of the given request) information system-related entity (e.g., devices, files, records, tables, processes, programs, networks, domains) containing or receiving information.
- As with subjects, objects have attributes that can be leveraged to make access control decisions.
 - A Microsoft Word document, for example, may have attributes such as title, subject, date, and author.
- Object attributes can often be extracted from the metadata of the object.
 - In particular, a variety of Web service metadata attributes may be relevant for access control purposes, such as ownership, service taxonomy, or even Quality of Service (QoS) attributes.



ABAC Model: Environment attributes

- These attributes have so far been largely ignored in most access control policies.
- They describe the operational, technical, and even situational environment or context in which the information access occurs.
 - For example, attributes, such as current date and time, the current virus/hacker activities, and the network's security level (e.g., Internet vs. intranet), are not associated with a particular subject nor a resource, but may nonetheless be relevant in applying an access control policy.



Attribute-Based Access Control (ABAC)

- Main obstacle to its adoption in real systems has been concern about the performance impact of evaluating predicates on both resource and user properties for each access
- Web services have been pioneering technologies through the introduction of the eXtensible Access Control Markup Language (XAMCL)
- There is considerable interest in applying the model to cloud services

